



WAF++ Ein Community getriebenes, Cloud agnostisches Well-Architected Framework

Sascha Lewandowski, Artem Lajko, Sebastian Meyer, Tim Urlaub

Version 1.0

Januar 26

Disclaimer

Dieses Dokument wurde von Mitgliedern der Community erstellt und stellt keine rechtsverbindliche Beratung dar. Alle Inhalte – einschließlich Beschreibungen, Bewertungen, Empfehlungen und technischen Ausführungen – basieren auf öffentlich verfügbaren Informationen, Erfahrungswerten sowie den persönlichen Einschätzungen der beteiligten Autoren.

WAF++ ist ein unabhängiges, community-getriebenes Konzept ohne kommerzielle Interessen und ohne Verbindung zu spezifischen Cloud-Anbietern. Die im Dokument enthaltenen Beispiele, Vergleiche oder Referenzen zu Cloud-Services dienen ausschließlich der technischen Einordnung und stellen keine Bewertung, Empfehlung oder Bevorzugung einzelner Anbieter dar.

Trotz sorgfältiger Recherche kann keine Gewähr für Richtigkeit, Vollständigkeit oder Aktualität der enthaltenen Informationen übernommen werden. Technologische Entwicklungen, regulatorische Änderungen oder Anbieteranpassungen können die beschriebenen Inhalte jederzeit beeinflussen. Jede Organisation trägt die Verantwortung, die beschriebenen Konzepte eigenständig zu prüfen, regulatorische Anforderungen zu bewerten und Entscheidungen auf Basis der individuellen Rahmenbedingungen zu treffen.

Die Autoren und Mitwirkenden übernehmen keine Haftung für Schäden oder Nachteile, die aus der Nutzung oder Umsetzung der im Dokument dargestellten Inhalte entstehen könnten.

Status	Release Date	Status	Autoren
Version 1.0	31.01.2026	Innitial	Sascha Lewandowski Artem Lajko Dr.-Ing. Sebastian Meyer Tim Urlaub

Multi-Cloud ist längst Realität – Sicherheit jedoch nicht. **69 % der Organisationen** [1] berichten bereits von Datenlecks, die direkt auf Sicherheits- und Konfigurationsfehler zurückzuführen sind. Fehlkonfiguration ist dabei kein Randthema, sondern ein akutes Risiko: **68 % der Experten** [2] stufen sie als eines der dringendsten Probleme moderner Cloud-Architekturen ein. Die Konsequenzen sind gravierend: Unternehmen mit hohem Maß an Non-Compliance verzeichnen durchschnittliche Schadenskosten von über 5 Millionen US-Dollar pro Sicherheitsvorfall.

Um diesen Risiken zu begegnen, haben Cloud-Anbieter ihre Best Practices in sogenannte **Well-Architected Frameworks (WAF)** überführt. Diese dienen mit ihren fünf bis sechs Säulen Architekten als Fundament, um Anwendungen professionell zu gestalten. Doch genau hier beginnt ein neues, strukturelles Problem: Bestehende WAFs sind streng auf den jeweiligen Provider zugeschnitten. Dadurch gehen Multi-Cloud-Fähigkeit, Vendor-Neutralität und vor allem die **Souveränität** verloren.

Das Problem der "strategischen Fehlkonfiguration"

Klassische WAFs geben einen beeinflussten Weg vor, der tief in proprietäre Services führt. Was dort als „Best Practice“ verkauft wird, entpuppt sich im Betrieb oft als strategische Falle:

- **Versteckte Kosten (Egress Fees):** Die Wahl eines Services erfolgt oft ohne Blick auf die Datenmobilität. Die Migration von nur einem Petabyte Daten kann bei Standard-Tarifen rund **54.000 US-Dollar** [3] an reinen Egress-Kosten verursachen. Laut dem Global Cloud Storage Index von Wasabi entfallen durchschnittlich **49 % der Cloud-Speicherbudgets** [4] auf versteckte Gebühren wie Egress und API-Zugriffe, was den ökonomischen Lock-in zementiert, den herkömmliche WAFs völlig ignorieren.
- **Die Transparenz-Lücke:** Die Thales Cloud Security Study 2025 zeigt, dass vielen Unternehmen der Überblick über ihre sensiblen Cloud-Daten fehlt: **61 % setzen fünf oder mehr Tools für Datenerkennung, -klassifizierung und -überwachung** ein [5] – ein Zeichen fragmentierter Transparenz. Gleichzeitig verlangen **97 % der deutschen Unternehmen einen souveränen Datenstandort** [6], doch für deutlich weniger ist die Souveränität des Cloud-Anbieters tatsächlich eine verbindliche Entscheidungsgrundlage. [7]

Bestehende WAFs bieten keine Antworten auf diese Souveränitäts-Fragen. Sie verschleiern vielmehr, wo Daten liegen, wie sie verschlüsselt sind und wer effektiv Zugriff hat. Durch diese fehlende Souveränität entstehen am Ende teure und aufwendige Migrationen, um regulatorische Anforderungen wie z.B. den EU Data Act nachträglich zu erfüllen.

WAF++

Hier setzt **WAF++** an. Es ist ein übergreifendes, Vendor-neutrales Framework mit sieben Säulen, das Souveränität und Datenhoheit in den Mittelpunkt stellt. Anstatt konkrete, proprietäre Lösungen vorzugeben, definiert WAF++ **architektonische Bausteine**.

Ziel ist es, ein unabhängiges Framework bereitzustellen, das auf verschiedene Cloud-Provider angewendet werden kann, ohne in die Egress-Falle oder die Transparenz-Lücke zu tappen. WAF++ bildet die Basis für eine Community, die Referenzarchitekturen als Open-Source-Projekt veröffentlicht – zugeschnitten auf die spezifischen regulatorischen und industriellen Anforderungen des europäischen Raums.

WAF++ entsteht aus der Idee, ein echtes und unabhängiges Framework aus der Community zu entwerfen, dass nicht konkrete Technologien, sondern Lösungsmuster in den Vordergrund stellt.

Wir betrachten Souveränität, als zentrales Element einer modernen, herstellernerutralen Cloud-Strategie, so dass sich das Framework nicht auf bestimmte Tools beschränkt und Methoden oder Technologien vermeidet, die zu einem Lock-In führen könnten.

Im Gegensatz zu etablierten Frameworks, die meist von einzelnen Anbietern entwickelt oder unterstützt werden, verfolgt dieses Framework einen Community-basierten Ansatz. Dabei bringen Experten und Anwender verschiedenste Perspektiven zusammen.

Das Framework verzichtet bewusst auf abstrakte Prinzipien und konzentriert sich stattdessen auf klare Strukturen und konkrete Sichtweisen, die durch praxisnahe Beispiele ergänzt werden. Wo Empfehlungen der Anbieter voneinander abweichen, erklärt das Framework die Hintergründe dieser Unterschiede.

Problemstellung

Unternehmen stehen beim Einsatz von Cloud-Lösungen heute vor zahlreichen Herausforderungen. Setzen sie strategisch auf einen einzelnen Cloud-Anbieter, drohen schnell Risiken wie Vendor Lock-In, eingeschränkte Ausfallsicherheit oder Problemfelder rund um Compliance – insbesondere angesichts der wachsenden Bedeutung von Souveränität.

Ein auf einen einzelnen Anbieter fokussiertes Design führt häufig dazu, dass Aspekte wie Workload-Migration, Kostenoptimierung über mehrere Clouds hinweg oder Interoperabilitätsmuster kaum berücksichtigt werden können, da die Anbieter primär ihr eigenes Ökosystem optimieren.

Bisherige Cloud-agnostische Ansätze, die nicht von Herstellern als Verkaufsargument genutzt werden, sind oft sehr zeit- und ressourcenintensiv, vor allem wenn große Beratungshäuser eingebunden sind.

Die inhaltliche Brücke zwischen Enterprise-Architekten auf der einen Seite und Entwicklern sowie Plattformingenieuren auf der anderen ist in aktuellen Materialien häufig zu groß. Zudem sind die Übergänge zwischen den Rollen und deren Verständnis selten nahtlos, sodass Unternehmen Schwierigkeiten haben, die Inhalte auf ihre eigene Situation zu übertragen.

Ziel des Whitepapers

Dieses Whitepaper dient als Diskussionsgrundlage für den Bedarf und die Notwendigkeit der beschriebenen Aspekte und bietet gleichzeitig einen ersten Einstieg in eine mögliche Ausarbeitung.

Gleichzeitig ist es ein Aufruf zur Beteiligung an interessierte Mitglieder Community, denn nur gemeinsam kann etwas entstehen, dass Mehrwert und Nutzen schafft.

Zielgruppe

Die Zielgruppe umfasst Cloud-Architekten und -Engineers, DevOps-Teams, IT-Manager, CTOs und CISOs sowie weitere technisch versierte Fachkräfte, die praktisch arbeiten, insbesondere Mitglieder der deutschsprachigen Cloud-Community.

Im Rahmen dieses Papers werden einige zentral Begrifflichkeiten verwendet, die je nach Kontext unterschiedlich verstanden werden können. Hier gelten die folgenden Definitionen.

Cloud

Der Begriff **Cloud** bezeichnet das Konzept der Bereitstellung von IT-Ressourcen wie Speicherplatz oder Rechenleistung auf flexible, skalierbare und bedarfsgerechte Weise. Dabei spielt es keine Rolle, welcher Anbieter diese Dienstleistungen bereitstellt.

Souverän

Souverän meint die Kontrolle und Selbstbestimmung über Daten, Einhaltung lokaler rechtlicher Rahmenbedingungen, Schutz vor fremdstaatlichem Zugriff sowie die Möglichkeit zur Umsetzung eigener Sicherheits- und Betriebsstandards aus.

Agnostisch

Agnostisch beschreibt die technologische Unabhängigkeit einer Lösung. Eine agnostische Cloud-Anwendung oder -Architektur ist so gestaltet, dass sie nicht an einen bestimmten Anbieter, eine Plattform oder Technologie gebunden ist.

Multi-Cloud / Cross-Cloud

Multi- oder Cross-Cloud bedeutet, dass Anforderungen flexibel zwischen verschiedenen **Clouds** verschoben werden können – ohne Anpassungen, da alle genutzten Funktionen überall verfügbar sind.

Vendor Lock-In

Der **Vendor Lock-In** beschreibt die Situation, dass eine implementierte Lösung von bestimmten Schlüsseltechnologien eines Cloud-Anbieters abhängig ist. Diese Technologien sind bei anderen Anbietern oft nicht verfügbar, was eine Migration erschwert oder unmöglich macht. Beispiele hierfür sind spezielle SaaS-Lösungen oder proprietäre IAM-Dienste.

Die Idee hinter Well-Architected Frameworks



Well-Architected Frameworks sind das Kondensat aus Best Practices und Standards, die sich in realen Projekten aus unterschiedlichen Bereichen bewährt haben. Sie basieren auf vielen Jahren Erfahrung mit realen Cloud-Architekturen in verschiedenen Industrien, Use Cases, Technologien und Herausforderungen und bieten damit ein Set an Standards, Strategien und Best Practices, mit denen sich resiliente, sichere, skalierbare und effiziente Anwendungen entwickeln lassen.

Ein WAF dient als Blueprint mit fünf bis sechs grundlegenden Säulen, die Orientierung bieten und Architekten helfen, Cloud Architekturen strukturiert zu evaluieren und zu verbessern, ohne dabei einengend zu wirken.

Ein zentrales Problem ist jedoch, dass die meisten WAFs providerspezifisch sind und dadurch einen Vendor Lock-In Effekt erzeugen. Um das volle Potenzial der jeweiligen Cloud auszuschöpfen, empfehlen die Frameworks oft spezifische Services, die nur beim jeweiligen Anbieter verfügbar sind. Dieses gute Konzept wird problematisch, sobald Multi Cloud oder Vendor Neutralität im Mittelpunkt stehen.

Allen großen WAF fehlt eine übergreifende Methodik, die regulatorische Anforderungen des europäischen Raums zu Datenschutz, Datensouveränität und Compliance berücksichtigt. Hier fehlt eine weitere Säule: Compliance, Governance und Datenschutz als Aspekte der Souveränität.

Ein WAF soll Architekten und Engineers ein Werkzeug an die Hand geben, um priorisiert Entscheidungen zu treffen, Chancen und Risiken transparent zu bewerten und alles mit den Individuellen den Zielen und Strategien des Unternehmens abzustimmen.

Der Aufbau auf den bestehenden Säulen und die Erweiterung um eine Säule der Souveränität ermöglicht es Unternehmen, flexibel auf technologische und regulatorische Veränderungen zu reagieren, ohne sich auf einen Anbieter festzulegen. Besonders im hochregulierten Bereich können sich Unternehmen nicht mit der Geschwindigkeit der Innovation der Cloud Provider bewegen, weil Prozesse hinterherhinken oder erst geschaffen werden müssen. Gleichzeitig sind Säulen wie Security und Compliance unverhandelbar und erfordern schnelle Umsetzung.



Providerspezifische Well-Architected Frameworks

Schaut man in die Landschaft der etablierten WAFs, so lohnt sich vor allem der Blick auf diese, die von den großen Hyperscalern GCP, AWS und Azure bereitgestellt werden.

Blickt man hier auf die grundlegenden Säulen, also die besonders beschriebenen Bereiche, so erkennt man eine große Übereinstimmung in allen Frameworks (siehe Abb. 1).

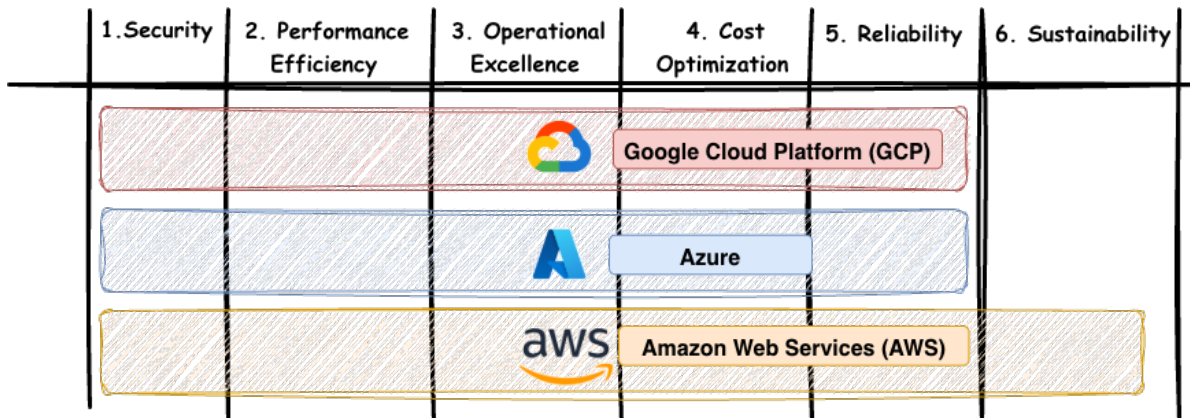


Abb. 1: Vergleich der WAFs von GCP, AWS und GCP

Alle Frameworks fördern kontinuierliche Verbesserung und stellen Tools zur Verfügung, die bei der Bewertung und Optimierung von Architekturen helfen. Sie enthalten alle die Säulen **Security**, **Performance Efficiency**, **Operational Excellence**, **Cost Optimization** und **Reliability**. Lediglich bei AWS ist die Säule **Sustainability** explizit ausgeführt.

Jedem Framework ist gemein, dass es auf die jeweiligen Stärken und Dienste des entsprechenden Cloud-Providers zugeschnitten ist. Der Mehrwert, den die Anwendung eines WAFs bringt, lässt sich in Beispielen gut erkennen:

- Netflix auf AWS nutzt die Prinzipien, um ein hochgradig skalierbares Streaming System aufzubauen. [QUELLE] <https://aws.amazon.com/solutions/case-studies/innovators/netflix/>
- Maersk nutzt auf Azure das Framework, um das Tracking System für Container zuverlässiger und kosteneffizienter zu gestalten. [QUELLE] <https://www.hso.co.uk/cloud-migration/azure/case-studies/maersk-logistics-security>
- Spotify verwendet GCP Best Practices, um Datenpipelines für mehr als 100 Milliarden Events täglich zu betreiben. [QUELLE] <https://www.acceldata.io/blog/data-engineering-best-practices-how-spotify>

Herausforderungen bei Multi Cloud Architekturen

Alle dieses Framework fokussieren sich wie beschrieben auf die Eigenschaften der Produkte des jeweiligen Herstellers. Es gibt kein übergreifendes WAF, das die allgemeinen Herausforderungen einer Multi-Cloud Strategie adressiert und gleichzeitig herstellerneutral bleibt. Bestehende Frameworks sind keine neutralen Ratgeber, sondern vielmehr **Navigationshilfen in geschlossenen Ökosystemen**. Ein wesentlicher Grund hierfür ist, dass in den meisten Fällen Probleme nicht Lösungs- sondern Service-orientiert gedacht und beschrieben werden.

Die konsequente Anwendung eines Frameworks führt daher bei Kombination mehrerer Cloud-Provider schnell in eine Komplexitätsfalle, da sich Architekturen und Services zu stark unterscheiden. Hier müssten ebenso mehrere WAFs berücksichtigt um kombiniert werden, was sich insbesondere bei der Nutzung von Vendor-nativen Technologien oft als wirtschaftlich unsinnig herausstellt.

Für das Ziel des Multi-Cloud Betriebs, basierend auf den jeweiligen WAF der Cloudbetreiber, fehlt ein verbindendes Element, wie sich technische und architektonische Entscheidungen über verschiedene Clouds hinweg verbinden und ersetzen lassen.

Zwar gibt es Ansätze wie die Well-Architected Designs von VMware, die sich zum Ziel setzen, cloud-agnostische Designs umzusetzen, letztlich erkaufte man sich diese Unabhängigkeit jedoch wieder durch eine Vendor-Spezifische Abstraktion (wie bspw. vSphere). Auch hier entsteht wieder eine Abhängigkeit und durch die Abstraktion eine Reduktion auf den kleinsten gemeinsamen Nenner ohne besondere Berücksichtigung der Eigenschaften von cloud-basierten Architekturen.

In einer Ära von NIS2, DORA und geopolitischen Instabilitäten ist Souveränität kein „Nice-to-have“ mehr, sondern eine Überlebensstrategie. Die Konzentration auf und der Lock-In bei einem bestimmten Anbieter steht diesem Ziel jedoch diametral entgegen. Um hier schon in der Architektur-Phase eine Entkopplung zu schaffen, ist es notwendig Architektur-Entscheidungen von technologischen Abhängigkeiten zu entkoppeln und sie stattdessen fest mit geschäftlicher Agilität und europäischer Compliance zu verdrachten. Dies geschieht durch die Bereitstellung von Bausteinen und Mustern, die unabhängig vom Cloud Provider umsetzbar sind.

Aus unserer Sicht ist es daher wesentlich eine weitere Säule in einem Framework zu definieren, um den Stellenwert der Souveränität zu unterstreichen. WAF++ nimmt die etablierten fünf Säulen aller Frameworks sowie die Positionierung von Sustainability von AWS als sechste Säule auf und ergänzt diese um die siebte Säule der Souveränität. Abb. 2 zeigt die sieben Säulen von WAF++ sowie deren Bedeutung.

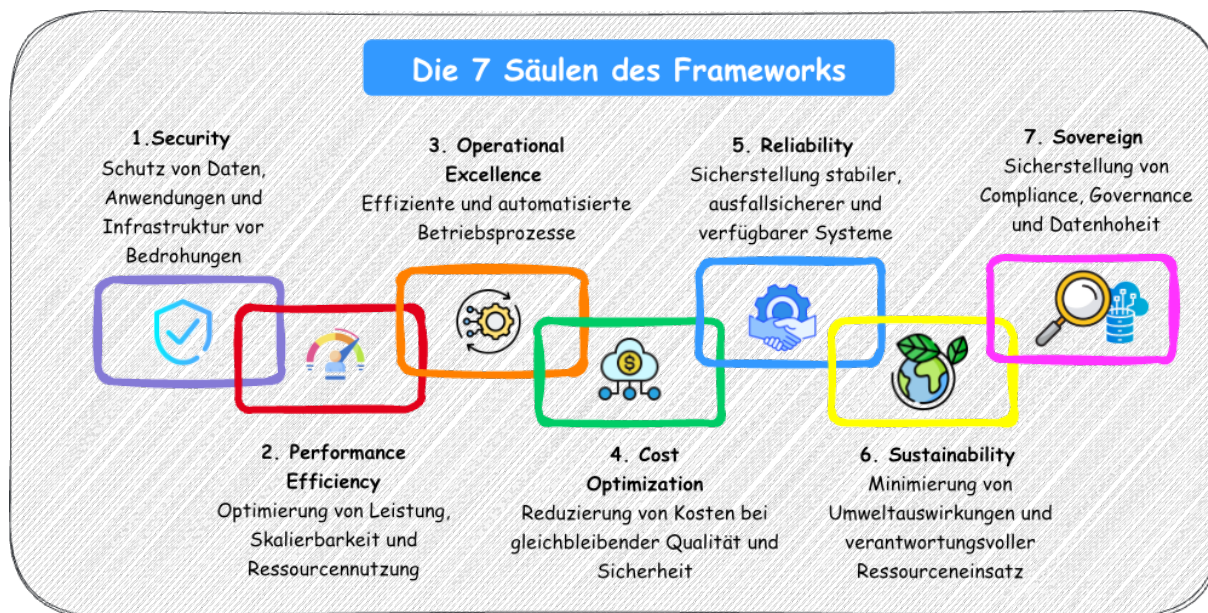


Abb. 2: Die sieben Säulen von WAF++

Ein übergreifendes Framework entfaltet seinen Wert erst durch die Relevanz für die handelnden Akteure. WAF++ adressiert die spezifischen Herausforderungen der unterschiedlichen Rollen im Unternehmen:

- **CTOs & Directors of Technology:** WAF++ sichert die strategische Handlungsfähigkeit. Es minimiert das Risiko eines Vendor Lock-ins und ermöglicht es, Workloads basierend auf geschäftlichen Anforderungen, statt technischer Sachzwänge zwischen Providern zu verschieben.
- **CISOs & Compliance Officer:** Die siebte Säule (Souveränität) bietet einen einheitlichen Kontrollrahmen für regulatorische Anforderungen wie NIS2 oder DORA. Sicherheit wird so providerübergreifend auditierbar und unabhängig von herstellerspezifischen Implementierungen.
- **Engineering Managers:** Das Framework fördert die Effizienz durch übertragbare Kompetenzen. Teams müssen nicht für jeden Cloud-Anbieter isoliertes Spezialwissen aufbauen, was die kognitive Last senkt und die Flexibilität im Personalmanagement erhöht.
- **Enterprise Architects:** WAF++ bietet einen herstellernerutralen Kompass für komplexe Multi-Cloud-Landschaften. Es ermöglicht eine konsistente Bewertung von Architekturentscheidungen und schafft eine gemeinsame Sprache zwischen Business-Strategie und IT-Umsetzung.
- **Platform Engineers & Product Managers:** Durch den Fokus auf portable Bausteine (Patterns) und Open-Source-Standards (z. B. CNCF) können stabile „Internal Developer Platforms“ (IDPs) geschaffen werden, die über Cloud-Grenzen hinweg konsistent funktionieren.
- **Application & Product Developers:** Entwickler profitieren von einer reduzierten Abhängigkeit von proprietären APIs. Dies ermöglicht eine schnellere Time-to-Market, da Anwendungen für eine logische Architektur statt für eine spezifische Cloud-Infrastruktur optimiert werden.

Die Analyse der bestehenden Cloud-Landschaft zeigt eine fundamentale Diskrepanz: Während etablierte WAFs der Hyperscaler wertvolle Best Practices innerhalb ihrer Ökosysteme liefern, führen sie systembedingt zu technologischer Abhängigkeit. Für Unternehmen im europäischen Raum, die Multi-Cloud-Flexibilität benötigen oder nutzen wollen und regulatorischen Anforderungen wie NIS2, DORA und GDPR unterliegen, existiert keine praktikable, vendor-neutrale Alternative.

Die zentralen Herausforderungen bleiben ungelöst:

- **Fehlende Portabilität:** Architekturentscheidungen binden Organisationen langfristig an einzelne Provider, ohne transparente Bewertung von Trade-offs
- **Regulatorische Lücken:** Europäische Souveränitätsanforderungen werden in keinem bestehenden Framework systematisch adressiert
- **Operative Komplexität:** Multi-Cloud-Umgebungen erfordern redundante Expertise ohne strukturierte Guidance über Provider-Grenzen hinweg

Das in diesem Paper skizzierte Konzept eines Cloud-agnostischen Well-Architected Framework (WAF++) adressiert diese Lücke durch einen Baustein-basierten Ansatz und die Integration einer siebten Säule "Compliance, Governance & Data Sovereignty".

Die Kernfrage lautet jedoch: Rechtfertigt der praktische Nutzen den Aufwand?

Zur Überprüfung der Umsetzbarkeit und des tatsächlichen Bedarfs eines solchen Frameworks schlagen wir daher die folgenden Evaluierungskategorien vor:

- **Quantifizierung des Problems:** Wie viele Organisationen in der DACH-Region erleben Vendor Lock-In als strategisches Hindernis? Welche konkreten Kosten entstehen durch provider-spezifische Architekturen?
- **Machbarkeitsnachweis:** Können Baustein-basierte Patterns echte Portabilität ermöglichen, ohne Overhead und Komplexität unverträglich zu erhöhen?
- **Community-Commitment:** Existiert ausreichendes Engagement in der deutschsprachigen Cloud-Community, um ein solches Framework zu entwickeln, zu pflegen und praktisch anzuwenden?
- **ROI-Nachweis:** Unter welchen Bedingungen rechtfertigt der Mehrwert eines agnostischen Frameworks die initialen Investitions- und laufenden Maintenance-Kosten?

- [1] T. Pangarkar, „Market.us,“ 21 01 2026. [Online]. Available: <https://scoop.market.us/cloud-security-statistics/>.
- [2] S. Blanton, „50+ Critical IT Compliance Statistics for 2024,“ 7 11 2024. [Online]. Available: <https://jumpcloud.com/blog/it-compliance-statistics>.
- [3] C. QUINN, „Last Week in AWS - The Compelling Economics of Cloudflare R2,“ 10 6 2021. [Online]. Available: <https://www.lastweekinaws.com/blog/the-compelling-economics-of-cloudflare-r2/>.
- [4] Wasabi, „Wasabi - Over Half of Organizations Globally Experience IT or Business Delays Due to Cloud Storage Fees, According to Wasabi's 2025 Global Cloud Storage Index,“ 24 2 2025. [Online]. Available: https://wasabi.com/company/newsroom/press-releases/over-half-of-organizations-globally-experience-it-or-business-delays-due-to-cloud-storage-fees-according-to-wasabi-s-2025-global-cloud-storage-index?utm_source=chatgpt.com.
- [5] Thales, „Cloud Security Study,“ 6 2025. [Online]. Available: <https://www.safeploy.com/files/202507/2025-thales-cloud-security-study.pdf>.

WAF++
<https://www.waf2p.dev>

Gründer
Sascha Lewandowski
Artem Lajko
Dr.-Ing. Sebastian Meyer
Tim Urlaub

